Báo cáo tích hợp — Đặc tả → Kripke → Sinh mã → CWE/CVE

Đặc tả: thanhtoan_donhang_v0

Mục lục

1. Đặc tả yêu cầu (Specification) 2

2. Kiểm chứng hình thức (Kripke/CTL) 4

2.1. Sơ đồ chuyển trạng thái 9

3. Mã C sinh ra & Static Checker (lỗi bộ nhớ) 12

4. Trích xuất AST/điều kiện & SMT (Z3) 14

5. Dynamic Fuzzing (hàm Python sinh ra) 14

6. Phân loại CWE/CVE tổng hợp 15

7. Test case truy vết từ đặc tả (tài liệu hóa) 17

1. Đặc tả yêu cầu (Specification)

Quy trình thanh toán trực tuyến 1 đơn hàng qua cổng thanh toán (có callback IPN), gồm 6 hành vi: H1 tiếp nhận yêu cầu (chép mã đơn vào bộ đệm), H2 tạo đơn (cấp phát mảng sản phẩm), H3 tính tổng tiền (số nguyên 32-bit, VND), H4 nhận callback từ cổng (chép mã giao dịch, xác thực chữ ký), H5 ghi log giao dịch, H6 đóng phiên (worker callback và worker timeout dùng chung phiên thanh toán). Bản v0 CÀI LỖI CÓ CHỦ ĐÍCH (18 trường hợp rủi ro bộ nhớ/tràn, trong đó 15 lỗi ẩn) để kiểm chứng khả năng phát hiện.

Mã yêu cầu	Loại	Ưu tiên	Nội dung
REQ-01	memory	HIGH	H1: Hàm phân tích mã đơn hàng (parse_order_id) không được ghi vượt biên bộ đệm, kể cả khi mã dài ĐÚNG 16 ký tự (C1.2, C1.3)
REQ-02	functional	HIGH	H1: Mã đơn hàng hợp lệ không được bị cắt cụt hoặc biến đổi khi lưu vào bộ đệm (C1.4)
REQ-03	memory	HIGH	H2: Kết quả cấp phát mảng sản phẩm (create_order_items) phải được kiểm tra NULL trước khi sử dụng (C2.2)
REQ-04	safety	HIGH	H2: Kích thước vùng nhớ cấp phát (số dòng x kích thước 1 dòng) không được tràn số hoặc âm (C2.3)
REQ-05	memory	MEDIUM	H2: Không được đọc trường dữ liệu của đơn hàng trước khi khởi tạo (C2.4)
REQ-06	safety	HIGH	H3: Tổng tiền đơn hàng không được tràn kiểu int32, kể cả khi cộng dồn nhiều dòng sản phẩm (C3.2, C3.3)
REQ-07	safety	HIGH	H3: Số lượng, đơn giá, giảm giá không được âm; tổng tiền phải thanh toán không được âm (C3.4)
REQ-08	functional	MEDIUM	H3: Hàm tính tiền trả góp không được gây lỗi không kiểm soát khi số kỳ hạn = 0 (C3.5)
REQ-09	memory	HIGH	H4: Hàm phân tích mã giao dịch từ callback (parse_gateway_txn_id) không được tràn bộ đệm (C4.2)

Mã yêu cầu	Loại	Ưu tiên	Nội dung
REQ-10	safety	HIGH	H4: Mọi callback phải được xác thực chữ ký; không được tồn tại nhánh ẩn bỏ qua kiểm tra (C4.3)
REQ-11	memory	MEDIUM	H5: Bản ghi log giao dịch (write_payment_log) phải được giải phóng trên mọi nhánh, kể cả nhánh lỗi (C5.2)
REQ-12	safety	MEDIUM	H5: Nội dung log có dữ liệu người dùng không được dùng làm chuỗi định dạng của printf (C5.3)
REQ-13	safety	HIGH	H6: Worker callback và worker timeout không được đồng thời giữ phiên thanh toán (mutual exclusion) (C6.2)
REQ-14	memory	HIGH	H6: Phiên thanh toán (close_payment_session) chỉ được giải phóng đúng 1 lần (C6.3)
REQ-15	memory	HIGH	H6: Không được truy cập phiên/bộ đệm thẻ (release_card_buffer) sau khi đã giải phóng (C6.4)
REQ-16	safety	HIGH	H6: Dữ liệu thẻ phải được xóa trắng bằng lệnh không bị trình biên dịch loại bỏ trước khi giải phóng (C6.5)
REQ-17	liveness	HIGH	Toàn luồng: mọi đường xử lý thanh toán cuối cùng phải kết thúc (thành công hoặc từ chối an toàn), không dừng ở trạng thái không an toàn
REQ-18	liveness	MEDIUM	Toàn luồng: luồng thanh toán thành công phải đạt tới được (mô hình không tầm thường) và đầu vào xấu phải có nhánh từ chối
NFR-01	non_functional	MEDIUM	Hệ thống xử lý tối thiểu 200 yêu cầu thanh toán/giây trên phần cứng tham chiếu

Mã yêu cầu	Loại	Ưu tiên	Nội dung
NFR-02	non_functional	HIGH	Phản hồi callback cho cổng thanh toán trong tối đa 3 giây (quá hạn cổng sẽ gửi lại IPN, gây callback lặp)
NFR-03	non_functional	HIGH	Bộ nhớ tiến trình không tăng quá 5% sau 1.000.000 giao dịch liên tiếp (dấu hiệu rò rỉ bộ nhớ)
NFR-04	non_functional	MEDIUM	Phiên thanh toán tự hết hạn sau 15 phút nếu không nhận được callback (worker timeout)
NFR-05	non_functional	HIGH	Dữ liệu thẻ không được tồn tại trong bộ nhớ quá thời gian xử lý 1 giao dịch (tinh thần PCI-DSS)
NFR-06	non_functional	LOW	Log giao dịch được lưu tối thiểu 12 tháng để đối soát
CON-01	constraint	HIGH	Mã đơn hàng tối đa 16 ký tự ASCII (16 ký tự cần 17 byte kể cả '\0')
CON-02	constraint	HIGH	Mã giao dịch của cổng thanh toán tối đa 20 ký tự ASCII
CON-03	constraint	HIGH	Mỗi đơn có 1–100 dòng sản phẩm; số lượng mỗi dòng 1–1000; đơn giá 0–50.000.000 VND; giá trị mỗi dòng tối đa 50.000.000 VND
CON-04	constraint	HIGH	Số tiền tính bằng VND; bản v0 dùng int 32-bit có dấu (tối đa 2.147.483.647); hạn mức 1 đơn là 2.000.000.000 VND
CON-05	constraint	MEDIUM	Kỳ hạn trả góp từ 1 đến 24 tháng
CON-06	constraint	MEDIUM	Chỉ dùng thư viện chuẩn C; phiên thanh toán được bảo vệ bằng mutex nhẹ
CON-07	constraint	HIGH	Bộ đệm số thẻ (PAN) 16 chữ số, chỉ tồn tại trong thời gian xử lý giao dịch

2. Kiểm chứng hình thức (Kripke/CTL)

Trạng thái deadlock: không có

Công thức CTL	Kết quả	Trạng thái thỏa
AG(!violation)	VI PHẠM	dung_khong_an_toan, ket_thuc_ok, ket_thuc_tu_choi
AG(!buffer_overflow)	VI PHẠM	dung_khong_an_toan, h2_doc_rac, h2_null, h2_sai_kich_thuoc, h3_chia_0, h3_so_am, h3_tran_so, h4_nhanh_an, h4_ok, h4_tu_choi_callback, h5_format_string, h5_ok, h5_ro_ri, h5_vao, h6_cb_giu, h6_con_so_the, h6_double_free, h6_giai_phong, h6_phien_ranh, h6_to_giu, h6_tranh_chap, h6_uaf, ket_thuc_ok, ket_thuc_tu_choi
AG(!off_by_one)	VI PHẠM	dung_khong_an_toan, h1_ok, h1_tran_bo_dem, h2_doc_rac, h2_null, h2_ok, h2_sai_kich_thuoc, h2_vao, h3_chia_0, h3_ok, h3_so_am, h3_tran_so, h3_vao, h4_nhanh_an, h4_ok, h4_tran_txn, h4_tu_choi_callback, h4_vao, h5_format_string, h5_ok, h5_ro_ri, h5_vao, h6_cb_giu, h6_con_so_the, h6_double_free, h6_giai_phong, h6_phien_ranh, h6_to_giu, h6_tranh_chap, h6_uaf, ket_thuc_ok, ket_thuc_tu_choi
AG(!null_deref)	VI PHẠM	dung_khong_an_toan, h1_tran_1_byte, h1_tran_bo_dem, h2_doc_rac, h2_ok, h2_sai_kich_thuoc, h3_chia_0, h3_ok, h3_so_am, h3_tran_so, h3_vao, h4_nhanh_an, h4_ok, h4_tran_txn, h4_tu_choi_callback, h4_vao, h5_format_string, h5_ok, h5_ro_ri, h5_vao, h6_cb_giu, h6_con_so_the, h6_double_free, h6_giai_phong, h6_phien_ranh, h6_to_giu, h6_tranh_chap, h6_uaf, ket_thuc_ok, ket_thuc_tu_choi

Công thức CTL	Kết quả	Trạng thái thỏa
AG(!heap_overflow)	VI PHẠM	dung_khong_an_toan, h1_tran_1_byte, h1_tran_bo_dem, h2_doc_rac, h2_null, h2_ok, h3_chia_0, h3_ok, h3_so_am, h3_tran_so, h3_vao, h4_nhanh_an, h4_ok, h4_tran_txn, h4_tu_choi_callback, h4_vao, h5_format_string, h5_ok, h5_ro_ri, h5_vao, h6_cb_giu, h6_con_so_the, h6_double_free, h6_giai_phong, h6_phien_ranh, h6_to_giu, h6_tranh_chap, h6_uaf, ket_thuc_ok, ket_thuc_tu_choi
AG(!uninit_read)	VI PHẠM	dung_khong_an_toan, h1_tran_1_byte, h1_tran_bo_dem, h2_null, h2_ok, h2_sai_kich_thuoc, h3_chia_0, h3_ok, h3_so_am, h3_tran_so, h3_vao, h4_nhanh_an, h4_ok, h4_tran_txn, h4_tu_choi_callback, h4_vao, h5_format_string, h5_ok, h5_ro_ri, h5_vao, h6_cb_giu, h6_con_so_the, h6_double_free, h6_giai_phong, h6_phien_ranh, h6_to_giu, h6_tranh_chap, h6_uaf, ket_thuc_ok, ket_thuc_tu_choi
AG(!int_overflow)	VI PHẠM	dung_khong_an_toan, h1_tran_1_byte, h1_tran_bo_dem, h2_doc_rac, h2_null, h2_sai_kich_thuoc, h3_chia_0, h3_ok, h3_so_am, h4_nhanh_an, h4_ok, h4_tran_txn, h4_tu_choi_callback, h4_vao, h5_format_string, h5_ok, h5_ro_ri, h5_vao, h6_cb_giu, h6_con_so_the, h6_double_free, h6_giai_phong, h6_phien_ranh, h6_to_giu, h6_tranh_chap, h6_uaf, ket_thuc_ok, ket_thuc_tu_choi

Công thức CTL	Kết quả	Trạng thái thỏa
AG(!negative_amount)	VI PHẠM	dung_khong_an_toan, h1_tran_1_byte, h1_tran_bo_dem, h2_doc_rac, h2_null, h2_sai_kich_thuoc, h3_chia_0, h3_ok, h3_tran_so, h4_nhanh_an, h4_ok, h4_tran_txn, h4_tu_choi_callback, h4_vao, h5_format_string, h5_ok, h5_ro_ri, h5_vao, h6_cb_giu, h6_con_so_the, h6_double_free, h6_giai_phong, h6_phien_ranh, h6_to_giu, h6_tranh_chap, h6_uaf, ket_thuc_ok, ket_thuc_tu_choi
AG(!div_by_zero)	VI PHẠM	dung_khong_an_toan, h1_tran_1_byte, h1_tran_bo_dem, h2_doc_rac, h2_null, h2_sai_kich_thuoc, h3_ok, h3_so_am, h3_tran_so, h4_nhanh_an, h4_ok, h4_tran_txn, h4_tu_choi_callback, h4_vao, h5_format_string, h5_ok, h5_ro_ri, h5_vao, h6_cb_giu, h6_con_so_the, h6_double_free, h6_giai_phong, h6_phien_ranh, h6_to_giu, h6_tranh_chap, h6_uaf, ket_thuc_ok, ket_thuc_tu_choi
AG(!hidden_bypass)	VI PHẠM	dung_khong_an_toan, h1_tran_1_byte, h1_tran_bo_dem, h2_doc_rac, h2_null, h2_sai_kich_thuoc, h3_chia_0, h3_so_am, h3_tran_so, h4_ok, h4_tran_txn, h4_tu_choi_callback, h5_format_string, h5_ok, h5_ro_ri, h5_vao, h6_cb_giu, h6_con_so_the, h6_double_free, h6_giai_phong, h6_phien_ranh, h6_to_giu, h6_tranh_chap, h6_uaf, ket_thuc_ok, ket_thuc_tu_choi

Công thức CTL	Kết quả	Trạng thái thỏa
AG(!mem_leak)	VI PHẠM	dung_khong_an_toan, h1_tran_1_byte, h1_tran_bo_dem, h2_doc_rac, h2_null, h2_sai_kich_thuoc, h3_chia_0, h3_so_am, h3_tran_so, h4_nhanh_an, h4_tran_txn, h4_tu_choi_callback, h5_format_string, h5_ok, h6_cb_giu, h6_con_so_the, h6_double_free, h6_giai_phong, h6_phien_ranh, h6_to_giu, h6_tranh_chap, h6_uaf, ket_thuc_ok, ket_thuc_tu_choi
AG(!format_string)	VI PHẠM	dung_khong_an_toan, h1_tran_1_byte, h1_tran_bo_dem, h2_doc_rac, h2_null, h2_sai_kich_thuoc, h3_chia_0, h3_so_am, h3_tran_so, h4_nhanh_an, h4_tran_txn, h4_tu_choi_callback, h5_ok, h5_ro_ri, h6_cb_giu, h6_con_so_the, h6_double_free, h6_giai_phong, h6_phien_ranh, h6_to_giu, h6_tranh_chap, h6_uaf, ket_thuc_ok, ket_thuc_tu_choi
AG(!race)	VI PHẠM	dung_khong_an_toan, h1_tran_1_byte, h1_tran_bo_dem, h2_doc_rac, h2_null, h2_sai_kich_thuoc, h3_chia_0, h3_so_am, h3_tran_so, h4_nhanh_an, h4_tran_txn, h5_format_string, h5_ro_ri, h6_con_so_the, h6_double_free, h6_giai_phong, h6_uaf, ket_thuc_ok, ket_thuc_tu_choi
AG(!double_free)	VI PHẠM	dung_khong_an_toan, h1_tran_1_byte, h1_tran_bo_dem, h2_doc_rac, h2_null, h2_sai_kich_thuoc, h3_chia_0, h3_so_am, h3_tran_so, h4_nhanh_an, h4_tran_txn, h5_format_string, h5_ro_ri, h6_con_so_the, h6_giai_phong, h6_uaf, ket_thuc_ok, ket_thuc_tu_choi

Công thức CTL	Kết quả	Trạng thái thỏa
AG(!use_after_free)	VI PHẠM	dung_khong_an_toan, h1_tran_1_byte, h1_tran_bo_dem, h2_doc_rac, h2_null, h2_sai_kich_thuoc, h3_chia_0, h3_so_am, h3_tran_so, h4_nhanh_an, h4_tran_txn, h5_format_string, h5_ro_ri, h6_con_so_the, h6_double_free, h6_giai_phong, ket_thuc_ok, ket_thuc_tu_choi
AG(!secret_residue)	VI PHẠM	dung_khong_an_toan, h1_tran_1_byte, h1_tran_bo_dem, h2_doc_rac, h2_null, h2_sai_kich_thuoc, h3_chia_0, h3_so_am, h3_tran_so, h4_nhanh_an, h4_tran_txn, h5_format_string, h5_ro_ri, h6_double_free, h6_tranh_chap, h6_uaf, ket_thuc_ok, ket_thuc_tu_choi
AF(flow_end)	VI PHẠM	ket_thuc_ok, ket_thuc_tu_choi
EF(payment_done)	ĐÚNG	h1_ok, h1_vao, h2_ok, h2_vao, h3_ok, h3_vao, h4_ok, h4_tu_choi_callback, h4_vao, h5_ok, h5_vao, h6_cb_giu, h6_giai_phong, h6_phien_ranh, h6_to_giu, ket_thuc_ok, start
EF(input_rejected)	VI PHẠM	ket_thuc_tu_choi
EG(!violation)	ĐÚNG	dung_khong_an_toan, h1_ok, h1_vao, h2_ok, h2_vao, h3_ok, h3_vao, h4_ok, h4_tu_choi_callback, h4_vao, h5_ok, h5_vao, h6_cb_giu, h6_giai_phong, h6_phien_ranh, h6_to_giu, ket_thuc_ok, ket_thuc_tu_choi, start
EF(cb_locked)	ĐÚNG	h1_ok, h1_vao, h2_ok, h2_vao, h3_ok, h3_vao, h4_ok, h4_tu_choi_callback, h4_vao, h5_ok, h5_vao, h6_cb_giu, h6_phien_ranh, h6_to_giu, h6_tranh_chap, start

Mutual exclusion: VI PHẠM (trạng thái nguy hiểm: h1_ok, h1_vao, h2_ok, h2_vao, h3_ok, h3_vao, h4_ok, h4_tu_choi_callback, h4_vao, h5_ok, h5_vao, h6_cb_giu, h6_phien_ranh, h6_to_giu, h6_tranh_chap, start)

2.1. Sơ đồ chuyển trạng thái

Sơ đồ: Mô hình chính: thanhtoan_donhang_v0 — phần 1/4

Mã TikZ (LaTeX) — dán trực tiếp vào tài liệu LaTeX có \usepackage{tikz} để biên dịch thành hình vector, thay cho ảnh tĩnh:

```
% Mô hình chính: thanhtoan_donhang_v0 — phần 1/4
\begin{tikzpicture}[
every node/.style={draw, circle, inner sep=2pt,
minimum size=8mm, align=center, font=\scriptsize},
->, >=stealth, thick, auto
]
\node[fill=blue!25] (nd_start) at (0.76,2.01) {start\\{\tiny safe,start}};
\node[fill=gray!15] (nd_h1_vao) at (0.52,-0.25) {h1\_vao\\{\tiny h1,receiving}};
\node[fill=red!35] (nd_h1_tran_bo_dem) at (-1.41,-1.57) {h1\_tran\_bo\_dem\\{\tiny buffer\_overflow,h1,violation}};
\node[fill=gray!15] (nd_h1_ok) at (-1.88,-0.08) {h1\_ok\\{\tiny h1,input\_ok}};
\node[fill=red!35] (nd_h1_tran_1_byte) at (1.52,1.55) {h1\_tran\_1\_byte\\{\tiny
buffer\_overflow,h1,off\_by\_one,violation}};
\node[fill=gray!15] (nd_dung_khong_an_toan) at (-1.03,1.69) {dung\_khong\_an\_toan\\{\tiny unsafe\_halt}};
\node[fill=gray!15] (nd_h2_vao) at (0.74,-1.95) {h2\_vao\\{\tiny allocating,h2}};
\node[fill=red!35] (nd_h3_tran_so) at (-1.72,-1.20) {h3\_tran\_so\\{\tiny h3,int\_overflow,violation}};
\node[fill=red!35] (nd_h3_so_am) at (-0.90,1.20) {h3\_so\_am\\{\tiny h3,negative\_amount,violation}};
\node[fill=red!35] (nd_h6_double_free) at (-0.08,-0.67) {h6\_double\_free\\{\tiny double\_free,h6,violation}};
\node[fill=red!35] (nd_h5_format_string) at (0.70,-1.13) {h5\_format\_string\\{\tiny format\_string,h5,violation}};
\node[fill=red!35] (nd_h2_doc_rac) at (-0.80,-0.35) {h2\_doc\_rac\\{\tiny h2,uninit\_read,violation}};
\node[rectangle, dashed, fill=gray!10] (nd___ghost__h6_con_so_the) at (1.08,1.79) {$\to$ h6\_con\_so\_the};
\node[rectangle, dashed, fill=gray!10] (nd___ghost__h6_uaf) at (-1.78,-0.25) {$\to$ h6\_uaf};
\node[rectangle, dashed, fill=gray!10] (nd___ghost__h2_sai_kich_thuoc) at (0.00,-1.65) {$\to$ h2\_sai\_kich\_thuoc};
\node[rectangle, dashed, fill=gray!10] (nd___ghost__h4_nhanh_an) at (1.89,-0.33) {$\to$ h4\_nhanh\_an};
\node[rectangle, dashed, fill=gray!10] (nd___ghost__h3_chia_0) at (-0.19,1.99) {$\to$ h3\_chia\_0};
\node[rectangle, dashed, fill=gray!10] (nd___ghost__h4_tran_txn) at (2.08,1.43) {$\to$ h4\_tran\_txn};
\node[rectangle, dashed, fill=gray!10] (nd___ghost__h2_null) at (-0.76,-1.65) {$\to$ h2\_null};
\node[rectangle, dashed, fill=gray!10] (nd___ghost__h5_ro_ri) at (1.89,0.46) {$\to$ h5\_ro\_ri};
\node[rectangle, dashed, fill=gray!10] (nd___ghost__h2_ok) at (-1.80,-0.96) {$\to$ h2\_ok};
\node[rectangle, dashed, fill=gray!10] (nd___ghost__h3_vao) at (-1.78,0.68) {$\to$ h3\_vao};
\node[rectangle, dashed, fill=gray!10] (nd___ghost__h6_tranh_chap) at (0.73,0.65) {$\to$ h6\_tranh\_chap};
\node[rectangle, dashed, fill=gray!10] (nd___ghost__h5_vao) at (2.20,-1.40) {$\to$ h5\_vao};
\draw (nd_start) -- (nd_h1_vao);
\draw (nd_h1_vao) -- (nd_h1_tran_bo_dem);
\draw (nd_h1_vao) -- (nd_h1_ok);
\draw (nd_h1_vao) -- (nd_h1_tran_1_byte);
\draw (nd_h1_tran_bo_dem) -- (nd_dung_khong_an_toan);
\draw (nd_h1_ok) -- (nd_h2_vao);
\draw (nd_h1_tran_1_byte) -- (nd_dung_khong_an_toan);
\draw (nd_dung_khong_an_toan) -- (nd_dung_khong_an_toan);
\draw (nd_h2_vao) -- (nd___ghost__h2_ok);
\draw (nd_h2_vao) -- (nd___ghost__h2_sai_kich_thuoc);
\draw (nd_h2_vao) -- (nd_h2_doc_rac);
\draw (nd_h2_vao) -- (nd___ghost__h2_null);
\draw (nd_h3_tran_so) -- (nd_dung_khong_an_toan);
\draw (nd_h3_so_am) -- (nd_dung_khong_an_toan);
\draw (nd_h6_double_free) -- (nd_dung_khong_an_toan);
\draw (nd_h5_format_string) -- (nd_dung_khong_an_toan);
\draw (nd_h2_doc_rac) -- (nd_dung_khong_an_toan);
\draw (nd___ghost__h6_con_so_the) -- (nd_dung_khong_an_toan);
\draw (nd___ghost__h6_uaf) -- (nd_dung_khong_an_toan);
\draw (nd___ghost__h2_sai_kich_thuoc) -- (nd_dung_khong_an_toan);
\draw (nd___ghost__h4_nhanh_an) -- (nd_dung_khong_an_toan);
\draw (nd___ghost__h3_chia_0) -- (nd_dung_khong_an_toan);
\draw (nd___ghost__h4_tran_txn) -- (nd_dung_khong_an_toan);
\draw (nd___ghost__h2_null) -- (nd_dung_khong_an_toan);
\draw (nd___ghost__h5_ro_ri) -- (nd_dung_khong_an_toan);
\draw (nd___ghost__h3_vao) -- (nd_h3_tran_so);
\draw (nd___ghost__h3_vao) -- (nd_h3_so_am);
\draw (nd___ghost__h6_tranh_chap) -- (nd_h6_double_free);
\draw (nd___ghost__h5_vao) -- (nd_h5_format_string);
\end{tikzpicture}
```

Sơ đồ: Mô hình chính: thanhtoan_donhang_v0 — phần 2/4

Mã TikZ (LaTeX) — dán trực tiếp vào tài liệu LaTeX có \usepackage{tikz} để biên dịch thành hình vector, thay cho ảnh tĩnh:

```
% Mô hình chính: thanhtoan_donhang_v0 — phần 2/4
\begin{tikzpicture}[
every node/.style={draw, circle, inner sep=2pt,
minimum size=8mm, align=center, font=\scriptsize},
->, >=stealth, thick, auto
]
\node[fill=red!35] (nd_h3_chia_0) at (0.16,1.70) {h3\_chia\_0\\{\tiny div\_by\_zero,h3,violation}};
\node[fill=red!35] (nd_h2_null) at (1.74,0.26) {h2\_null\\{\tiny h2,null\_deref,violation}};
\node[fill=red!35] (nd_h5_ro_ri) at (-0.68,-0.80) {h5\_ro\_ri\\{\tiny h5,mem\_leak,violation}};
\node[fill=red!35] (nd_h6_uaf) at (-1.69,0.49) {h6\_uaf\\{\tiny h6,use\_after\_free,violation}};
\node[fill=red!35] (nd_h4_nhanh_an) at (1.12,1.15) {h4\_nhanh\_an\\{\tiny h4,hidden\_bypass,violation}};
\node[fill=red!35] (nd_h4_tran_txn) at (-1.22,1.51) {h4\_tran\_txn\\{\tiny buffer\_overflow,h4,violation}};
\node[fill=red!35] (nd_h2_sai_kich_thuoc) at (1.84,-0.73) {h2\_sai\_kich\_thuoc\\{\tiny
alloc\_size\_overflow,h2,heap\_overflow,violation}};
\node[fill=red!35] (nd_h6_con_so_the) at (-1.16,-0.57) {h6\_con\_so\_the\\{\tiny h6,secret\_residue,violation}};
\node[fill=gray!15] (nd_h2_ok) at (-1.42,0.89) {h2\_ok\\{\tiny allocated,h2,initialized}};
\node[fill=gray!15] (nd_h3_vao) at (-0.01,0.41) {h3\_vao\\{\tiny computing,h3}};
\node[fill=red!35] (nd_h6_tranh_chap) at (0.07,-1.23) {h6\_tranh\_chap\\{\tiny cb\_locked,h6,race,to\_locked,violation}};
\node[fill=gray!15] (nd_h5_vao) at (0.11,-0.20) {h5\_vao\\{\tiny h5,logging}};
\node[rectangle, dashed, fill=gray!10] (nd___ghost__dung_khong_an_toan) at (0.65,1.44) {$\to$ dung\_khong\_an\_toan};
\node[rectangle, dashed, fill=gray!10] (nd___ghost__h2_vao) at (-0.02,-0.02) {$\to$ h2\_vao};
\node[rectangle, dashed, fill=gray!10] (nd___ghost__h4_vao) at (0.17,-0.50) {$\to$ h4\_vao};
\node[rectangle, dashed, fill=gray!10] (nd___ghost__h6_giai_phong) at (0.63,-1.78) {$\to$ h6\_giai\_phong};
\node[rectangle, dashed, fill=gray!10] (nd___ghost__h3_ok) at (-0.82,1.64) {$\to$ h3\_ok};
\node[rectangle, dashed, fill=gray!10] (nd___ghost__h3_so_am) at (1.73,0.81) {$\to$ h3\_so\_am};
\node[rectangle, dashed, fill=gray!10] (nd___ghost__h3_tran_so) at (-0.75,-2.19) {$\to$ h3\_tran\_so};
\node[rectangle, dashed, fill=gray!10] (nd___ghost__h6_double_free) at (1.77,-0.52) {$\to$ h6\_double\_free};
\node[rectangle, dashed, fill=gray!10] (nd___ghost__h6_cb_giu) at (-1.74,-1.14) {$\to$ h6\_cb\_giu};
\node[rectangle, dashed, fill=gray!10] (nd___ghost__h6_to_giu) at (-1.44,-0.23) {$\to$ h6\_to\_giu};
\node[rectangle, dashed, fill=gray!10] (nd___ghost__h5_ok) at (-0.37,1.51) {$\to$ h5\_ok};
\node[rectangle, dashed, fill=gray!10] (nd___ghost__h5_format_string) at (1.38,0.29) {$\to$ h5\_format\_string};
\node[rectangle, dashed, fill=gray!10] (nd___ghost__h4_ok) at (-0.04,-2.20) {$\to$ h4\_ok};
\draw (nd_h3_chia_0) -- (nd___ghost__dung_khong_an_toan);
\draw (nd_h2_null) -- (nd___ghost__dung_khong_an_toan);
\draw (nd_h5_ro_ri) -- (nd___ghost__dung_khong_an_toan);
\draw (nd_h6_uaf) -- (nd___ghost__dung_khong_an_toan);
\draw (nd_h4_nhanh_an) -- (nd___ghost__dung_khong_an_toan);
\draw (nd_h4_tran_txn) -- (nd___ghost__dung_khong_an_toan);
\draw (nd_h2_sai_kich_thuoc) -- (nd___ghost__dung_khong_an_toan);
\draw (nd_h6_con_so_the) -- (nd___ghost__dung_khong_an_toan);
\draw (nd_h2_ok) -- (nd_h3_vao);
\draw (nd_h3_vao) -- (nd___ghost__h3_ok);
\draw (nd_h3_vao) -- (nd___ghost__h3_so_am);
\draw (nd_h3_vao) -- (nd___ghost__h3_tran_so);
\draw (nd_h3_vao) -- (nd_h3_chia_0);
\draw (nd_h6_tranh_chap) -- (nd___ghost__h6_double_free);
\draw (nd_h6_tranh_chap) -- (nd_h6_uaf);
\draw (nd_h5_vao) -- (nd_h5_ro_ri);
\draw (nd_h5_vao) -- (nd___ghost__h5_ok);
\draw (nd_h5_vao) -- (nd___ghost__h5_format_string);
\draw (nd___ghost__h2_vao) -- (nd_h2_null);
\draw (nd___ghost__h2_vao) -- (nd_h2_sai_kich_thuoc);
\draw (nd___ghost__h2_vao) -- (nd_h2_ok);
\draw (nd___ghost__h4_vao) -- (nd_h4_nhanh_an);
\draw (nd___ghost__h4_vao) -- (nd_h4_tran_txn);
\draw (nd___ghost__h6_giai_phong) -- (nd_h6_con_so_the);
\draw (nd___ghost__h6_cb_giu) -- (nd_h6_tranh_chap);
\draw (nd___ghost__h6_to_giu) -- (nd_h6_tranh_chap);
\draw (nd___ghost__h4_ok) -- (nd_h5_vao);
\end{tikzpicture}
```

Sơ đồ: Mô hình chính: thanhtoan_donhang_v0 — phần 3/4

Mã TikZ (LaTeX) — dán trực tiếp vào tài liệu LaTeX có \usepackage{tikz} để biên dịch thành hình vector, thay cho ảnh tĩnh:

```
% Mô hình chính: thanhtoan_donhang_v0 — phần 3/4
\begin{tikzpicture}[
every node/.style={draw, circle, inner sep=2pt,
minimum size=8mm, align=center, font=\scriptsize},
->, >=stealth, thick, auto
```

```
]
\node[fill=gray!15] (nd_h4_vao) at (-0.19,0.13) {h4\_vao\\{\tiny callback\_received,h4}};
\node[fill=gray!15] (nd_h6_giai_phong) at (1.13,1.42) {h6\_giai\_phong\\{\tiny h6,releasing}};
\node[fill=gray!15] (nd_h3_ok) at (-1.76,-1.13) {h3\_ok\\{\tiny amount\_ok,h3}};
\node[fill=gray!15] (nd_h6_cb_giu) at (-0.42,0.00) {h6\_cb\_giu\\{\tiny cb\_locked,h6}};
\node[fill=gray!15] (nd_h6_to_giu) at (1.03,0.30) {h6\_to\_giu\\{\tiny h6,to\_locked}};
\node[fill=gray!15] (nd_h4_ok) at (-0.15,1.75) {h4\_ok\\{\tiny callback\_verified,h4}};
\node[fill=gray!15] (nd_h5_ok) at (1.85,-0.92) {h5\_ok\\{\tiny h5,log\_freed}};
\node[fill=gray!15] (nd_h4_tu_choi_callback) at (-0.68,-1.63) {h4\_tu\_choi\_callback\\{\tiny callback\_rejected,h4}};
\node[fill=gray!15] (nd_ket_thuc_ok) at (-1.16,1.81) {ket\_thuc\_ok\\{\tiny flow\_end,mem\_clean,payment\_done}};
\node[fill=gray!15] (nd_h6_phien_ranh) at (0.55,-0.38) {h6\_phien\_ranh\\{\tiny h6,sess\_free}};
\node[rectangle, dashed, fill=gray!10] (nd___ghost__h4_nhanh_an) at (1.16,-1.56) {$\to$ h4\_nhanh\_an};
\node[rectangle, dashed, fill=gray!10] (nd___ghost__h4_tran_txn) at (-1.97,-0.31) {$\to$ h4\_tran\_txn};
\node[rectangle, dashed, fill=gray!10] (nd___ghost__h6_con_so_the) at (0.65,2.20) {$\to$ h6\_con\_so\_the};
\node[rectangle, dashed, fill=gray!10] (nd___ghost__h3_vao) at (-2.15,0.36) {$\to$ h3\_vao};
\node[rectangle, dashed, fill=gray!10] (nd___ghost__h6_tranh_chap) at (0.23,-1.99) {$\to$ h6\_tranh\_chap};
\node[rectangle, dashed, fill=gray!10] (nd___ghost__h5_vao) at (1.88,-0.05) {$\to$ h5\_vao};
\draw (nd_h4_vao) -- (nd___ghost__h4_nhanh_an);
\draw (nd_h4_vao) -- (nd_h4_ok);
\draw (nd_h4_vao) -- (nd___ghost__h4_tran_txn);
\draw (nd_h4_vao) -- (nd_h4_tu_choi_callback);
\draw (nd_h6_giai_phong) -- (nd_ket_thuc_ok);
\draw (nd_h6_giai_phong) -- (nd___ghost__h6_con_so_the);
\draw (nd_h3_ok) -- (nd_h4_vao);
\draw (nd_h6_cb_giu) -- (nd___ghost__h6_tranh_chap);
\draw (nd_h6_cb_giu) -- (nd_h6_giai_phong);
\draw (nd_h6_to_giu) -- (nd_h6_giai_phong);
\draw (nd_h6_to_giu) -- (nd___ghost__h6_tranh_chap);
\draw (nd_h4_ok) -- (nd___ghost__h5_vao);
\draw (nd_h5_ok) -- (nd_h6_phien_ranh);
\draw (nd_h4_tu_choi_callback) -- (nd_h6_phien_ranh);
\draw (nd_ket_thuc_ok) -- (nd_ket_thuc_ok);
\draw (nd_h6_phien_ranh) -- (nd_h6_cb_giu);
\draw (nd_h6_phien_ranh) -- (nd_h6_to_giu);
\draw (nd___ghost__h3_vao) -- (nd_h3_ok);
\draw (nd___ghost__h5_vao) -- (nd_h5_ok);
\end{tikzpicture}
```

Sơ đồ: Mô hình chính: thanhtoan_donhang_v0 — phần 4/4

Mã TikZ (LaTeX) — dán trực tiếp vào tài liệu LaTeX có \usepackage{tikz} để biên dịch thành hình vector, thay cho ảnh tĩnh:

```
% Mô hình chính: thanhtoan_donhang_v0 — phần 4/4
\begin{tikzpicture}[
every node/.style={draw, circle, inner sep=2pt,
minimum size=8mm, align=center, font=\scriptsize},
->, >=stealth, thick, auto
]
\node[fill=gray!15] (nd_ket_thuc_tu_choi) at (0.00,0.00) {ket\_thuc\_tu\_choi\\{\tiny
flow\_end,input\_rejected,mem\_clean}};
\draw (nd_ket_thuc_tu_choi) -- (nd_ket_thuc_tu_choi);
\end{tikzpicture}
```

3. Mã C sinh ra & Static Checker (lỗi bộ nhớ)

Mã C sinh từ đặc tả

```
#include <stdio.h>
#include <stdlib.h>
#include <string.h>

/* sinh từ đặc tả 'thanhtoan_donhang_v0', hàm 'parse_order_id', kind='buffer_copy' */
void parse_order_id(const char *raw_order_id) {
char buffer[16];
strcpy(buffer, raw_order_id); /* sinh từ đặc tả: buffer-overflow */
printf("%s\n", buffer);
}

/* sinh từ đặc tả 'thanhtoan_donhang_v0', hàm 'parse_gateway_txn_id', kind='buffer_copy' */
void parse_gateway_txn_id(const char *raw_txn_id) {
```

```
char buffer[20];
strcpy(buffer, raw_txn_id); /* sinh từ đặc tả: buffer-overflow */
printf("%s\n", buffer);
}

/* sinh từ đặc tả 'thanhtoan_donhang_v0', hàm 'create_order_items', kind='alloc_release' */
void create_order_items(void) {
int *buf = malloc(sizeof(int) * 100);
buf[0] = 0;
free(buf);
}

/* sinh từ đặc tả 'thanhtoan_donhang_v0', hàm 'write_payment_log', kind='alloc_release' */
void write_payment_log(void) {
int *buf = malloc(sizeof(int) * 32);
buf[0] = 0;
/* sinh từ đặc tả: memory-leak (thiếu free) */
}

/* sinh từ đặc tả 'thanhtoan_donhang_v0', hàm 'close_payment_session', kind='alloc_release' */
void close_payment_session(void) {
int *buf = malloc(sizeof(int) * 4);
buf[0] = 0;
free(buf);
free(buf); /* sinh từ đặc tả: double-free */
}

/* sinh từ đặc tả 'thanhtoan_donhang_v0', hàm 'release_card_buffer', kind='alloc_release' */
void release_card_buffer(void) {
int *buf = malloc(sizeof(int) * 16);
buf[0] = 0;
free(buf);
buf[0] = 1; /* sinh từ đặc tả: use-after-free */
}

/* sinh từ đặc tả 'thanhtoan_donhang_v0', hàm 'add_shipping_fee', kind='arithmetic' */
int add_shipping_fee(int subtotal, int shipping_fee) {
return subtotal + shipping_fee;
}
```

Dòng	Mức độ	Loại lỗi	Mô tả
8	HIGH	dangerous-function	Sử dụng hàm không an toàn 'strcpy()' — dễ gây buffer overflow. Goi y: dung strncpy thay the.
15	HIGH	dangerous-function	Sử dụng hàm không an toàn 'strcpy()' — dễ gây buffer overflow. Goi y: dung strncpy thay the.
28	MEDIUM	memory-leak	Con trỏ 'buf' được cấp phát (malloc/calloc/realloc) nhưng không thấy free() trong hàm write_payment_log() — nghi ngờ rò rỉ bộ nhớ
38	HIGH	double-free	Double-free trên con trỏ 'buf' (đã free() tại dòng 37) trong hàm close_payment_session()

Dòng	Mức độ	Loại lỗi	Mô tả
46	HIGH	use-after-free	Khả năng sử dụng con trỏ 'buf' sau khi free() (freed tại dòng 45) trong hàm release_card_buffer()

4. Trích xuất AST/điều kiện & SMT (Z3)

Hàm	Biến	Điều kiện	Vòng lặp	Độ phức tạp McCabe	Độ sâu lồng nhau
parse_order_id	['buffer']	[]	[]	1	1
parse_gateway_txn_id	['buffer']	[]	[]	1	1
create_order_items	['buf']	[]	[]	1	1
write_payment_log	['buf']	[]	[]	1	1
close_payment_session	['buf']	[]	[]	1	1
release_card_buffer	['buf']	[]	[]	1	1
add_shipping_fee	[]	[]	[]	1	1
installment_amount	[]	[]	[]	1	1
ipn_debug_bypass	[]	['merchant_id == 31337', 'debug_pin == 8080']	[]	3	3

Kiểm tra	Kết quả SMT	Model (nếu SAT)
order_total_int32	sat	{'subtotal': 2147483647, 'shipping_fee': 1}
order_total_int32 (int32 overflow?)	sat	{'subtotal': -1, 'shipping_fee': -2147483648}
line_amount_mul	sat	{'price': 33765495, 'qty': 509}
line_amount_mul (int32 overflow?)	sat	{'price': 2147483647, 'qty': -2}
accumulated_total	sat	{'total_before': 2147483647, 'line_total': 1}
accumulated_total (int32 overflow?)	sat	{'total_before': -1, 'line_total': -2147483648}
alloc_bytes	sat	{'n_items': 67107688, 'item_size': 48}
alloc_bytes (int32 overflow?)	sat	{'n_items': -1130510287, 'item_size': 837492479}
negative_total	sat	{'subtotal': 0, 'discount': 1}
negative_total (int32 overflow?)	sat	{'subtotal': 0, 'discount': -2147483648}

5. Dynamic Fuzzing (hàm Python sinh ra)

Hàm Python 'installment_amount'

```
def installment_amount(total, months):
return total // months
```

Hàm Python 'ipn_debug_bypass'

```
def ipn_debug_bypass(merchant_id, debug_pin):
if merchant_id == 31337:
if debug_pin == 8080:
raise ValueError('magic value reached')
return merchant_id + debug_pin
```

Hàm	Kết quả fuzzing
installment_amount	black-box: 11/300 lan crash
ipn_debug_bypass	concolic: crash_input={'merchant_id': 31337, 'debug_pin': 8080} sau 3 lan thu

6. Phân loại CWE/CVE tổng hợp

Nguồn	Vị trí	Loại phát hiện	CWE	Ví dụ CVE minh họa
ch1	cong thuc AG(!violation)	safety-property-violation	CWE-693 — Protection Mechanism Failure	-
ch1	cong thuc AG(!buffer_overflow)	safety-property-violation	CWE-693 — Protection Mechanism Failure	-
ch1	cong thuc AG(!off_by_one)	safety-property-violation	CWE-693 — Protection Mechanism Failure	-
ch1	cong thuc AG(!null_deref)	safety-property-violation	CWE-693 — Protection Mechanism Failure	-
ch1	cong thuc AG(!heap_overflow)	safety-property-violation	CWE-693 — Protection Mechanism Failure	-
ch1	cong thuc AG(!uninit_read)	safety-property-violation	CWE-693 — Protection Mechanism Failure	-
ch1	cong thuc AG(!int_overflow)	safety-property-violation	CWE-693 — Protection Mechanism Failure	-
ch1	cong thuc AG(!negative_amount)	safety-property-violation	CWE-693 — Protection Mechanism Failure	-

Nguồn	Vị trí	Loại phát hiện	CWE	Ví dụ CVE minh họa
ch1	cong thuc AG(!div_by_zero)	safety-property-violation	CWE-693 — Protection Mechanism Failure	-
ch1	cong thuc AG(!hidden_bypass)	safety-property-violation	CWE-693 — Protection Mechanism Failure	-
ch1	cong thuc AG(!mem_leak)	safety-property-violation	CWE-693 — Protection Mechanism Failure	-
ch1	cong thuc AG(!format_string)	safety-property-violation	CWE-693 — Protection Mechanism Failure	-
ch1	cong thuc AG(!race)	safety-property-violation	CWE-693 — Protection Mechanism Failure	-
ch1	cong thuc AG(!double_free)	safety-property-violation	CWE-693 — Protection Mechanism Failure	-
ch1	cong thuc AG(!use_after_free)	safety-property-violation	CWE-693 — Protection Mechanism Failure	-
ch1	cong thuc AG(!secret_residue)	safety-property-violation	CWE-693 — Protection Mechanism Failure	-
ch1	cong thuc AF(flow_end)	safety-property-violation	CWE-693 — Protection Mechanism Failure	-
ch1	cong thuc EF(input_rejected)	safety-property-violation	CWE-693 — Protection Mechanism Failure	-
ch1	mô hình trạng thái	mutual-exclusion-violation	CWE-667 — Improper Locking	-
ch2	dong 8	dangerous-function	CWE-120 — Buffer Copy without Checking Size of Input	CVE-2003-0352 (2003)

Nguồn	Vị trí	Loại phát hiện	CWE	Ví dụ CVE minh họa
ch2	dong 15	dangerous-function	CWE-120 — Buffer Copy without Checking Size of Input	CVE-2003-0352 (2003)
ch2	dong 28	memory-leak	CWE-401 — Missing Release of Memory after Effective Lifetime	-
ch2	dong 38	double-free	CWE-415 — Double Free	-
ch2	dong 46	use-after-free	CWE-416 — Use After Free	CVE-2019-0708 (2019)
ch3	order_total_int32	integer-overflow	CWE-190 — Integer Overflow or Wraparound	CVE-2016-5195 (2016)
ch3	line_amount_mul	integer-overflow	CWE-190 — Integer Overflow or Wraparound	CVE-2016-5195 (2016)
ch3	accumulated_total	integer-overflow	CWE-190 — Integer Overflow or Wraparound	CVE-2016-5195 (2016)
ch3	alloc_bytes	integer-overflow	CWE-190 — Integer Overflow or Wraparound	CVE-2016-5195 (2016)
ch3	negative_total	integer-overflow	CWE-190 — Integer Overflow or Wraparound	CVE-2016-5195 (2016)
ch4	installment_amount	uncontrolled-crash	CWE-248 — Uncaught Exception	-
ch4	ipn_debug_bypass	uncontrolled-crash	CWE-248 — Uncaught Exception	-

7. Test case truy vết từ đặc tả (tài liệu hóa)

ID	Ưu tiên	Tiêu đề	Truy vết yêu cầu	Kết quả mong đợi
TC-01	HIGH	Mã đơn dài đúng 16 ký tự và dài 100 ký tự	REQ-01, CON-01	v0: dangerous-function strcpy (CWE-120), 2 công thức VI PHẠM; v1: 0 phát hiện, công thức ĐÚNG
TC-02	HIGH	Bản sửa của phần mềm có cắt cụt mã đơn 16 ký tự không	REQ-02, CON-01	M1-v1a: AG(!truncated) VI PHẠM (mã bị cắt, phần mềm không báo); M1-v1b: ĐÚNG
TC-03	HIGH	Cấp phát mảng sản phẩm	REQ-03, REQ-04, REQ-05	Phần mềm quét mã: 0 phát hiện; mô hình M2-v0: 3 công thức VI PHẠM; alloc_bytes SAT (v0) / UNSAT (v1)
TC-04	HIGH	Tổng tiền tràn int32	REQ-06, CON-03, CON-04	v0: SAT kèm phản ví dụ, BMC vi phạm tại bước 48 (total = 2.160.000.000); v1: UNSAT, BMC không vi phạm
TC-05	HIGH	Số tiền âm do giảm giá	REQ-07, CON-03	v0: SAT (vd discount > subtotal); v1: UNSAT
TC-06	MEDIUM	Trả góp với số kỳ hạn = 0	REQ-08, CON-05	v0: tìm được ít nhất 1 crash ZeroDivisionError (CWE-248/369); v1: hàm đã thay bằng kiểm tra 1 <= months <= 24
TC-07	HIGH	Mã giao dịch callback dài hơn 20 ký tự	REQ-09, CON-02	v0: dangerous-function (CWE-120); v1: 0 phát hiện
TC-08	HIGH	Nhánh ẩn bỏ qua xác thực chữ ký	REQ-10	Black-box: 0 lần chạm nhánh; concolic: tìm đúng (31337, 8080) sau vài lần thử (CWE-912)
TC-09	MEDIUM	Rò rỉ bộ nhớ khi ghi log lỗi	REQ-11, NFR-03	v0: memory-leak (CWE-401); v1: 0 phát hiện

ID	Ưu tiên	Tiêu đề	Truy vết yêu cầu	Kết quả mong đợi
TC-10	MEDIUM	Chuỗi định dạng trong log	REQ-12	M5-v0: AG(!format_string) VI PHẠM (CWE-134); M5-v1: ĐÚNG
TC-11	HIGH	Callback và timeout cùng đóng phiên	REQ-13, NFR-04	v0: Mutual exclusion VI PHẠM tại h6_tranh_chap (CWE-667); v1: ĐÚNG
TC-12	HIGH	Double free và use-after-free khi đóng phiên	REQ-14, REQ-15	v0: double-free (CWE-415) và use-after-free (CWE-416); v1: 0 phát hiện
TC-13	HIGH	Số thẻ còn trong bộ nhớ sau khi giải phóng	REQ-16, NFR-05, CON-07	M6-v0: VI PHẠM (CWE-226/244, CWE-14); M6-v1 (explicit_bzero trước free): ĐÚNG
TC-14	HIGH	Toàn luồng thanh toán	REQ-17, REQ-18	Không deadlock; v0: AF(flow_end) và EF(input_rejected) VI PHẠM; v1: tất cả ĐÚNG